

ISO/IEC 42001

The international standard for an Artificial Intelligence Management System (AIMS) — what it requires, how PDCA drives continual improvement, roles, certification, and a practical checklist.

AIMS Requirements

Certifiable Standard

PDCA Cycle

Practical Checklist

01

Plan

02

Do

03

Check

04

Act

FOUNDATIONS

What ISO/IEC 42001 Is

The first international management-system standard for artificial intelligence — requirements for establishing, implementing, maintaining, and continually improving an AI Management System (AIMS).

Why It Exists

Organizations that develop, provide, or use AI need a repeatable way to govern it — not a one-off model review, but an ongoing management system. ISO/IEC 42001 gives organizations of any size and sector a common structure for AI governance: policies, objectives, roles, controls, monitoring, and continual improvement.

What Makes It Different From a Model Checklist

Think beyond one model. ISO/IEC 42001 is not primarily about evaluating a single model's accuracy. It is about the organization's overall capability to manage AI responsibly and consistently across multiple systems, teams, and use cases — over time, not just at launch.

Who It's For

- **Providers** who design, build, or supply AI systems or models.
- **Deployers** who use AI systems within their own operations.
- Organizations across any sector — technology, financial services, healthcare, public sector, manufacturing, and beyond.
- Any size of organization, from a small team running one GenAI pilot to a multinational with dozens of AI systems in production.

What an AIMS Delivers

- ▶ A defined AI policy and governance structure.
- ▶ Clear responsibilities and accountable owners for AI systems and AI-related risks.
- ▶ A process for identifying AI risks and opportunities.
- ▶ AI objectives that can be monitored and reviewed.
- ▶ Operational controls across the AI lifecycle.
- ▶ Documented information and evidence.
- ▶ Monitoring, measurement, internal audit, management review, corrective action, and continual improvement.

CERTIFIABLE STANDARD

Unlike guidance documents, ISO/IEC 42001 is written as a set of auditable requirements. Organizations can seek third-party certification against it, similar in structure to how ISO/IEC 27001 works for information security management.

THE AIMS STRUCTURE

The Management-System Structure

ISO/IEC 42001 follows the common high-level structure shared by ISO management-system standards, which is what makes it possible to integrate with existing systems like ISO/IEC 27001 or ISO 9001.

Seven Core Areas

AREA	WHAT IT MEANS FOR AI GOVERNANCE
Context	Understand the organization, AI use, stakeholders, external/internal issues, and scope of the AIMS.
Leadership	Establish AI policy, leadership commitment, governance responsibilities, and accountability.
Planning	Assess AI risks and opportunities; define objectives and actions to achieve them.
Support	Provide competence, awareness, communication, resources, and controlled documentation.
Operation	Implement and control AI lifecycle activities, risk treatments, impact considerations, and relevant controls.
Performance evaluation	Monitor results, evaluate effectiveness, conduct internal audits, and perform management review.
Improvement	Correct problems, learn from incidents/audits, and continually improve the AIMS.

Scoping the AIMS

Before anything else, the organization defines the **scope** of its AIMS — which AI systems, business units, locations, and activities are covered. A narrow first scope (e.g., one product line or one GenAI platform) is a common and reasonable starting point; the scope can expand as the management system matures.

INTERESTED PARTIES TO CONSIDER

- Customers and end users affected by AI system outputs.
- Employees, especially those whose work is affected by or who operate AI systems.
- Regulators and industry bodies with applicable requirements.
- Suppliers, vendors, and third-party model or platform providers.
- Investors, partners, and the wider public where AI use has societal impact.

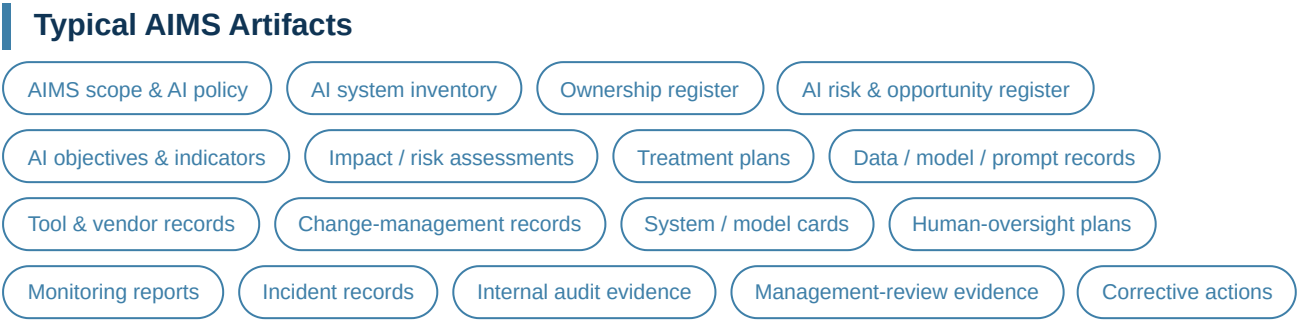
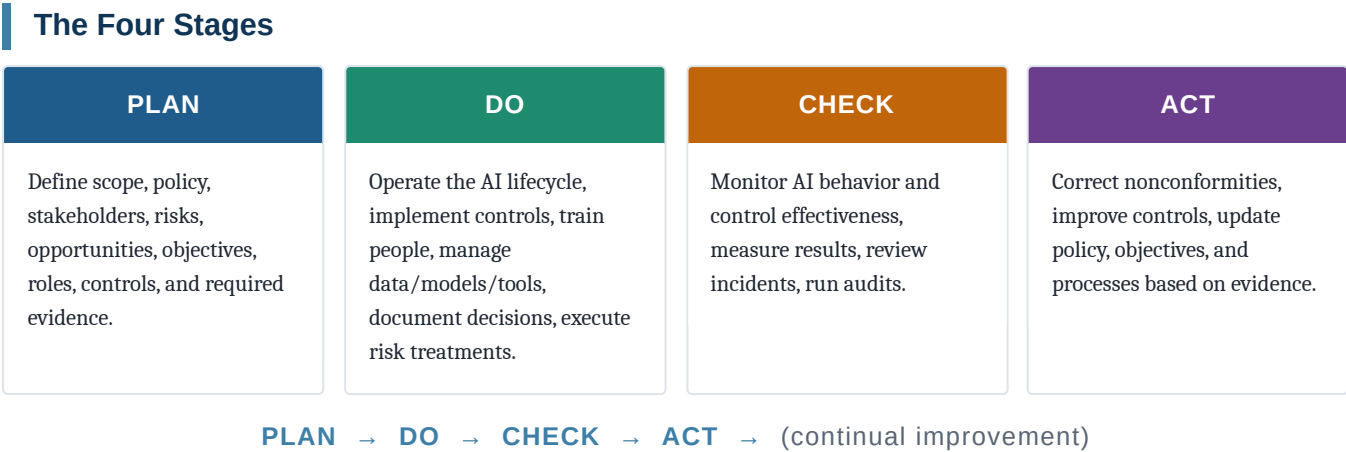
Documented Information

The standard expects documented information appropriate to the organization's size and complexity — not paperwork for its own sake, but evidence that policies, risk decisions, controls, and reviews actually happened and can be traced.

CONTINUAL IMPROVEMENT

How ISO/IEC 42001 Works: Plan – Do – Check – Act

ISO/IEC 42001 uses the familiar management-system idea of continual improvement, explained through the PDCA cycle.



EXAMPLE — GENAI CUSTOMER-SUPPORT PLATFORM

PLAN identifies hallucination, privacy, prompt-injection, and content-safety risks. **DO** implements grounding, guardrails, access controls, human escalation, and documentation. **CHECK** measures failures and reviews incidents. **ACT** updates prompts, models, policies, controls, or approval rules based on the evidence.

GOVERNANCE

Roles & Responsibilities in an AIMS

ISO/IEC 42001 does not mandate specific job titles, but it does require clear, assigned responsibility and authority for the AI management system to function.

Common Roles Across an AIMS

Top Management

Sets the AI policy, demonstrates leadership commitment, allocates resources, and integrates AI governance into overall business strategy.

AIMS Owner / AI Governance Lead

Coordinates the management system day-to-day: scope, documentation, internal audit schedule, and management-review preparation.

AI System Owners

Accountable for individual AI systems — their risk assessments, controls, monitoring, and lifecycle changes.

Risk & Compliance

Supports risk criteria, treatment decisions, regulatory mapping, and residual-risk acceptance.

Security & Privacy

Contributes controls for data protection, access management, and technical security across the AI lifecycle.

Operations / Engineering

Implements technical controls, monitoring, logging, and change management for AI systems in production.

Cross-Functional by Design

Because AI risk touches technical, organizational, legal, and ethical dimensions at once, an effective AIMS usually draws on a standing cross-functional group — sometimes called an AI governance committee or council — rather than leaving AI oversight to one team in isolation.

Accountability, not just activity. The standard cares less about who performs a task and more about whether someone is clearly accountable for the outcome, with the authority and competence to act on it.

Competence & Awareness

The AIMS should ensure people doing AI-related work have appropriate competence — through training, experience, or qualification — and that relevant staff are aware of the AI policy, their role in it, and the implications of not following it.

CERTIFICATION

The Certification Pathway

ISO/IEC 42001 follows the same general certification model used by other ISO management-system standards — an external audit process leading to a time-bound certificate.

Typical Certification Journey

●

Gap analysis

Compare current AI governance practices against the standard's requirements to identify what's missing.

●

Build the AIMS

Establish policy, scope, risk process, controls, and documentation; operate it long enough to generate real evidence.

●

Internal audit

Test the AIMS against the standard internally and correct gaps before the external audit.

●

Management review

Leadership formally reviews AIMS performance, risks, and improvement needs.

●

Stage 1 audit

External auditor reviews documentation and readiness for the full assessment.

●

Stage 2 audit

External auditor assesses whether the AIMS is implemented effectively in practice, not just on paper.

●

Certification decision

Certification body issues the certificate if requirements are met, typically valid for three years.

Staying Certified

ACTIVITY	PURPOSE
Surveillance audits	Periodic external checks (commonly annual) confirming the AIMS is still operating effectively between full recertifications.
Internal audits	Ongoing self-checks to catch nonconformities early and demonstrate continual improvement.
Management review	Regular leadership review of AIMS performance, incidents, risks, and resourcing.
Recertification audit	A fuller reassessment, typically at the end of the certification cycle, to renew the certificate.

Certification is a milestone, not the goal.

The certificate confirms a point-in-time assessment; the actual value is the ongoing discipline of managing AI risk and governance consistently, which the PDCA cycle is designed to sustain.

CONTEXT

How ISO/IEC 42001 Fits the Wider AI Governance Landscape

ISO/IEC 42001 rarely operates alone. Organizations typically use it as the governance backbone and connect it to more specific guidance and regulation.

Where Other Frameworks Fit In

FRAMEWORK	RELATIONSHIP TO ISO/IEC 42001
ISO/IEC 23894	Supplies deeper, AI-specific risk-management guidance for the risk-assessment activity required inside the AIMS.
NIST AI RMF	A complementary voluntary framework (GOVERN/MAP/MEASURE/MANAGE); many organizations map its outcomes onto AIMS controls, especially for US-facing operations.
EU AI Act	A binding regulation with its own risk-based legal obligations; an AIMS can provide much of the organizational infrastructure needed to demonstrate compliance, though certification against 42001 does not itself guarantee legal compliance.
ISO/IEC 27001	Information security management; many organizations run 42001 alongside an existing 27001 system, sharing common structure, audits, and evidence where practical.

A PRACTICAL WAY TO SEQUENCE ADOPTION

- 1 Define the AIMS scope and AI policy.
- 2 Create an AI inventory and identify system owners.
- 3 Define risk criteria, stakeholder expectations, and governance responsibilities.
- 4 Apply detailed risk analysis (e.g., ISO/IEC 23894-style) for each material AI use case.
- 5 Select controls and create treatment plans with owners and target dates.
- 6 Operate AI lifecycle processes and retain evidence.
- 7 Monitor, audit, review, and continually improve.

One sentence summary. ISO/IEC 42001 gives an organization the governance operating system for AI; other frameworks and regulations plug into it to add depth on risk analysis, regional compliance, or sector-specific obligations.

WORKING REFERENCE

Practical ISO/IEC 42001 Checklist

A practical learning aid — not a substitute for the complete standard or a certification audit checklist.

PLAN — GOVERNANCE & SCOPE ☐ AIMS scope defined and approved. ☐ AI policy established and communicated. ☐ Interested parties and their requirements identified. ☐ AI system inventory and accountable owners maintained. ☐ AI objectives and governance metrics defined. ☐ Roles for AI, security, privacy, legal, risk, and operations assigned.	DO — OPERATE THE AIMS ☐ Risk and opportunity assessment performed for each material AI use case. ☐ Controls selected and implemented with clear ownership. ☐ Competence and awareness of AI policy confirmed for relevant staff. ☐ Data, model, prompt, tool, and third-party controls documented. ☐ Human oversight and escalation designed for high-impact actions. ☐ Documented information controlled and retained.
CHECK — MONITOR & AUDIT ☐ Monitoring measures AI behavior and control effectiveness. ☐ Drift, new threats, failures, and misuse trigger re-assessment. ☐ Internal audit programme evaluates AIMS effectiveness. ☐ Incidents and nonconformities are recorded and investigated. ☐ Management review conducted at planned intervals. ☐ Evidence retained for audits and internal review.	ACT — IMPROVE ☐ Corrective actions are tracked to closure. ☐ Root causes of nonconformities are addressed, not just symptoms. ☐ Lessons learned are fed back into policy, controls, and training. ☐ AIMS scope and objectives are revisited as the organization's AI use evolves. ☐ Certification / surveillance audit findings are actioned with owners and dates. ☐ Continual improvement is evidenced over successive cycles, not just claimed.

Reference Set

ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system.
ISO/IEC 23894:2023 — Information technology — Artificial intelligence — Guidance on risk management (complementary risk-analysis guidance).
Accredited certification bodies — for organizations pursuing formal third-party certification.
Related ISO/IEC AI standards may also be relevant, including terminology, impact-assessment, lifecycle, and data-quality standards depending on the use case.

REMEMBER

ISO/IEC 42001 is the governance operating system for AI — policy, roles, risk, controls, evidence, and continual improvement, run on a PDCA cycle. Scope it deliberately, build evidence as you go, and treat certification as a milestone in an ongoing discipline rather than a one-time project.